ESEN

C I B E R S E G U R I D A D

Proyecto Final · Entregable E.07

Desarrollo de control CIS (política + SOP + controles)

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Formato oficial del entregable E.07 de la Guía del Estudiante del Proyecto Final (2026), llenado íntegramente

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del equipo.... 3
2. Instrucciones de uso.... 3
3. Desarrollo de control CIS (política + SOP + controles).... 3
Control 12 — Gestión de la infraestructura de red.... 3
F.0 Selección de los seis controles (común a los seis archivos).... 3
F.1 Identificación del control.... 4
F.2 Política (el qué y el porqué).... 4
F.3 SOP — procedimiento operativo (el cómo).... 5
F.4 Controles por tipo.... 6
Supuestos declarados en este entregable.... 6
Control 13 — Monitoreo y defensa de la red.... 6
F.1 Identificación del control.... 6
F.2 Política (el qué y el porqué).... 7
F.3 SOP — procedimiento operativo (el cómo).... 7
F.4 Controles por tipo.... 8
Control 6 — Gestión del control de acceso.... 8
F.1 Identificación del control.... 8
F.2 Política (el qué y el porqué).... 9
F.3 SOP — procedimiento operativo (el cómo).... 9
F.4 Controles por tipo.... 10
Control 7 — Gestión continua de vulnerabilidades.... 10
F.1 Identificación del control.... 10
F.2 Política (el qué y el porqué).... 11
F.3 SOP — procedimiento operativo (el cómo).... 12
F.4 Controles por tipo.... 12
Control 11 — Recuperación de datos.... 13
F.1 Identificación del control.... 13
F.2 Política (el qué y el porqué).... 13
F.3 SOP — procedimiento operativo (el cómo).... 14
F.4 Controles por tipo.... 14
Control 15 — Gestión de proveedores de servicios.... 14
F.1 Identificación del control.... 14
F.2 Política (el qué y el porqué).... 15
F.3 SOP — procedimiento operativo (el cómo).... 16
F.4 Controles por tipo.... 16
Cierre del entregable.... 16

1. Identificación del equipo

Campo	Registro
Equipo	Nexo Crítico Consultores
Organización del catálogo	Energía Nacional S.A. de C.V. (ENSA) — perfil n.° 4
Grupo de Implementación asignado	IG3
Integrantes	Seis, con los cinco roles cubiertos
Fecha de entrega	viernes 30 de octubre de 2026 (H4)
Versión del documento	v1.0

2. Instrucciones de uso

- La plantilla se completa para la organización asignada al equipo en el Catálogo de Empresas 2026.
- La sección E.07 de la Guía del Estudiante del Proyecto Final describe el objetivo de este entregable, sus insumos, los pasos, el llenado campo por campo, un ejemplo resuelto, los errores frecuentes, el checklist de cierre y la fecha de entrega.
- Este archivo es el ejemplo resuelto con ENSA: conserva el formato, los encabezados y el pie de la plantilla en blanco, y muestra el nivel de detalle que el proyecto espera. El equipo trabaja sobre su propia plantilla y con su propia organización.
- Nombre del archivo de entrega en Moodle: E07_Desarrollo_Control_CIS_<Control>_<Equipo>.docx (o .pdf).

3. Desarrollo de control CIS (política + SOP + controles)

Control 12 — Gestión de la infraestructura de red

Cada uno de los seis controles a profundidad se desarrolla con esta estructura completa, en un archivo por control. Extensión de referencia: 3–5 páginas de desarrollo por control (F.1 a F.4), sin contar portada, índice, instrucciones ni la sección F.0.

F.0 Selección de los seis controles (común a los seis archivos)

La misma tabla va en los seis archivos: los seis controles elegidos, los riesgos Críticos y Altos de E.05 que cubre cada uno y el criterio del paso 2 de la guía que decidió su lugar (conteo de riesgos, riesgo Crítico, suma de inherentes, SLE, riesgo que ningún otro candidato trata, tratamiento valorado en D.6).

Lugar	Control CIS v8.1	Riesgos que cubre (ID de E.05)	Criterio que decidió su lugar
1	Control 12 — Gestión de la infraestructura de red	R-01 (Crítico), R-03 y R-11	Tres riesgos, uno Crítico; trata el punto único de falla de segmentación del BIA
2	Control 13 — Monitoreo y defensa de la red	R-01 (Crítico), R-03 y R-10	Tres riesgos, uno Crítico; única detección en la red OT (R-10)
3	Control 6 — Gestión del control de acceso	R-02 y R-07 (Críticos) y R-09	Tres riesgos, dos Críticos

Lugar	Control CIS v8.1	Riesgos que cubre (ID de E.05)	Criterio que decidió su lugar
4	Control 7 — Gestión continua de vulnerabilidades	R-12, con efecto sobre R-01 y R-04	Único candidato que trata R-12
5	Control 11 — Recuperación de datos	R-06 y el impacto de R-01	Acota la pérdida del SLE-01, el mayor del BIA
6	Control 15 — Gestión de proveedores de servicios	R-09, R-02 y R-14	Único candidato que trata R-14

F.1 Identificación del control

Campo	Contenido
Control CIS v8.1	Control 12 — Gestión de la infraestructura de red
Salvaguardas del IG asignado en este control	Ocho salvaguardas, todas dentro del IG3: 12.1 infraestructura de red actualizada (IG1), 12.2 arquitectura de red segura (IG2), 12.3 gestión segura de la infraestructura (IG2), 12.4 diagramas de arquitectura (IG2), 12.5 AAA centralizado (IG2), 12.6 protocolos seguros de gestión y comunicación (IG2), 12.7 VPN y AAA para dispositivos remotos (IG2), 12.8 recursos de cómputo dedicados para administración (IG3). Se diseñan ahora 12.1, 12.2, 12.3, 12.4 y 12.6; pasan al roadmap de E.10 las salvaguardas 12.5, 12.7 y 12.8, que dependen del servicio de autenticación centralizado que el control 6 implanta primero
Riesgos que mitiga	R-01 (Crítico), R-03 (Alto) y R-11 (Alto) de la matriz de E.05
Correspondencia ISO	ISO/IEC 27002:2022, controles 8.20 seguridad de redes, 8.21 seguridad de servicios de red y 8.22 segregación de redes
Función CSF 2.0	Proteger (PR.IR — resiliencia de la infraestructura tecnológica)

F.2 Política (el qué y el porqué)

Sección	Contenido
Propósito	Impedir que un incidente originado en la red corporativa de TI alcance la red de tecnología operacional que sostiene el telecontrol de la red eléctrica. El perfil de ENSA declara un aislamiento que en la práctica no es real, y el análisis de impacto cifra en USD 62 000 cada hora sin telecontrol, con un período máximo tolerable de cuatro horas
Alcance	Toda la infraestructura de red de ENSA: red corporativa de TI, red de tecnología operacional, la zona intermedia entre ambas, los enlaces con las doce subestaciones principales y los equipos de comunicación de la cabecera de medición inteligente
Declaraciones de política	1. Todo tráfico entre la red de TI y la red OT atraviesa la zona intermedia y un punto de filtrado con reglas aprobadas por la Jefatura de Seguridad de la Información. 2. Ninguna sesión se origina desde la red de TI hacia la red OT sin pasar por un anfitrión de salto ubicado en la zona intermedia. 3. Las reglas de filtrado se justifican por proceso de negocio, tienen dueño declarado y vencen a los doce meses si no se revalidan. 4. Los diagramas de arquitectura de red se mantienen actualizados y se revisan tras todo cambio. 5. Los equipos de red se administran por protocolos cifrados y con credenciales nominales. 6. Ningún equipo de red opera con versión de software fuera de soporte del fabricante. 7. Toda conexión nueva entre la red OT y cualquier otra red exige evaluación de riesgos previa y aprobación de la Gerencia General

Sección	Contenido
Roles y responsabilidades	Aprueba: Gerencia General. Rinde cuentas: Jefatura de Seguridad de la Información. Ejecuta: unidad TI/TO con la Gerencia de Operaciones de Red. Verifica: oficial de cumplimiento en la auditoría interna de E.09. La asignación coincide con las filas de la RACI de E.06 sobre operación de la segmentación y revisión de reglas
Cumplimiento y excepciones	El incumplimiento se trata como falta grave conforme al reglamento interno. Toda excepción se solicita por escrito, con justificación de negocio, medida compensatoria y fecha de vencimiento no mayor a noventa días; la aprueba la Jefatura de Seguridad y la registra el inventario de excepciones que la auditoría interna revisa
Revisión	Revisión anual de la política y revisión trimestral del conjunto de reglas de filtrado. Dueño del documento: Jefatura de Seguridad de la Información

F.3 SOP — procedimiento operativo (el cómo)

Sección	Contenido
Objetivo y disparador	Mantener y verificar la segmentación entre la red de TI y la red OT. Se ejecuta de forma trimestral por calendario, y de forma inmediata ante toda solicitud de cambio que afecte el punto de filtrado o ante un incidente que involucre a cualquiera de las dos redes
Responsable y frecuencia	Analista de seguridad de tecnología de operación, con el administrador de red de TI/TO. Frecuencia trimestral y por evento
Pasos numerados	1. Exportar el conjunto de reglas vigente del punto de filtrado y compararlo con el conjunto aprobado en el repositorio de configuración. 2. Listar las diferencias y exigir la solicitud de cambio que respalda cada una; las reglas sin respaldo se documentan como hallazgo. 3. Identificar las reglas con más de doce meses sin revalidación y solicitar al dueño su renovación o su retiro. 4. Verificar con una prueba controlada que no existe ruta directa entre la red de TI y la red OT: intento de conexión a tres servicios del entorno de control desde una estación de la red corporativa, con evidencia de bloqueo. 5. Revisar que el anfitrión de salto de la zona intermedia exija autenticación multifactor y registre la sesión. 6. Actualizar los diagramas de arquitectura con los cambios aprobados del trimestre. 7. Comprobar la versión de software de los equipos de red contra el ciclo de vida publicado por el fabricante. 8. Emitir el reporte trimestral con hallazgos, reglas retiradas y plan de corrección
Evidencia generada	Reporte trimestral de revisión de reglas con su lista de diferencias; registro de la prueba controlada de bloqueo con fecha y resultado; diagramas de arquitectura versionados; inventario de excepciones vigentes. Esta evidencia alimenta los indicadores IND-01 e IND-02 de E.09
Escalamiento	Toda regla que permita tráfico directo entre TI y OT sin respaldo se retira dentro de las 24 horas y se informa a la Jefatura de Seguridad y a la Gerencia de Operaciones de Red. Si el retiro afecta la operación, la decisión sube a la Gerencia General en la misma jornada y queda registrada como excepción con vencimiento

F.4 Controles por tipo

Tipo	Qué documenta el equipo (2–4 por control)
Técnicos	Dos cortafuegos industriales en alta disponibilidad que crean la zona intermedia entre la red de TI y la red OT, con política de denegación por defecto y reglas por proceso · anfitrión de salto en la zona intermedia con autenticación multifactor y grabación de sesión · administración de los equipos de red por protocolos cifrados, con el CIS Benchmark de Fortinet FortiGate 7.4.x para los cortafuegos corporativos —la lista oficial de CIS no publica el de FortiOS 7.2, la versión que declara la ficha, y 7.4 es la versión a la que se migra, declarado así— y, para los conmutadores Siemens RUGGEDCOM, que no figuran en la lista oficial, la guía de endurecimiento del fabricante · retiro de los protocolos de gestión sin cifrado en los enlaces con subestaciones · hallazgo de fin de soporte: FortiOS 7.2 terminó su soporte de ingeniería el 31 de marzo de 2025 y su soporte el 30 de septiembre de 2026 (ciclo de vida de producto de Fortinet); la migración a FortiOS 7.4 pasa a E.10 como iniciativa de corto plazo
Administrativos	Procedimiento de solicitud, aprobación y vencimiento de reglas con dueño declarado · revisión trimestral documentada del conjunto de reglas · mantenimiento y versionado de los diagramas de arquitectura · cláusula de evaluación de riesgos previa para toda conexión nueva hacia la red OT
Físicos	Armarios de comunicación de subestación con cerradura controlada y registro de apertura · el centro de control y el centro de datos conservan el control de acceso existente, y el repetidor de radio sin respaldo de energía se atiende como iniciativa del roadmap (SPOF-07)

Supuestos declarados en este entregable

Solo se declara como supuesto lo que ni el perfil del catálogo ni la ficha de datos del cliente traen: un dato que la ficha trae nunca se sustituye por un supuesto. Cada supuesto lleva un identificador global y correlativo en todo el proyecto (S-01, S-02…): el entregable continúa la numeración del anterior y E.11 los consolida en su Anexo A. Cuando el entregable no declara supuestos, la primera fila lo dice.

ID (S-nn, numeración global)	Supuesto	Fundamento u origen
—	Sin supuestos nuevos en este entregable.	Los seis controles usan la pila tecnológica, los respaldos y los controles que ya existen de la ficha de datos del cliente, y los riesgos de E.05.

Control 13 — Monitoreo y defensa de la red

F.1 Identificación del control

Campo	Contenido
Control CIS v8.1	Control 13 — Monitoreo y defensa de la red
Salvaguardas del IG asignado en este control	Once salvaguardas, todas dentro del IG3: 13.1 alertas centralizadas de eventos de seguridad (IG2), 13.2 IDS en host (IG2), 13.3 IDS de red (IG2), 13.4 filtrado de tráfico entre segmentos (IG2), 13.5 control de acceso para activos remotos (IG2), 13.6 registros de flujo de red (IG2), 13.7 IPS en host (IG3), 13.8 IPS de red (IG3), 13.9 control de acceso a nivel de puerto (IG3), 13.10 filtrado de capa de aplicación (IG3), 13.11 ajuste de umbrales de alerta (IG3). Se diseñan ahora 13.1, 13.3, 13.4, 13.6 y 13.11; pasan al roadmap 13.2, 13.5, 13.7, 13.8, 13.9 y 13.10, en ese orden de dependencia. El control 13 no tiene salvaguardas IG1, de modo que su presencia en el baseline proviene íntegramente de la asignación IG3

Campo	Contenido
Riesgos que mitiga	R-01 (Crítico), R-03 (Alto) y R-10 (Alto)
Correspondencia ISO	ISO/IEC 27002:2022, controles 8.16 actividades de monitoreo, 8.20 seguridad de redes y 8.22 segregación de redes
Función CSF 2.0	Detectar (DE.CM — monitoreo continuo)

F.2 Política (el qué y el porqué)

Sección	Contenido
Propósito	Detectar la actividad anómala en la red corporativa y en la red de tecnología operacional a tiempo para contenerla dentro del período máximo tolerable de interrupción de cuatro horas del proceso de control de red. El análisis de impacto documentó que hoy ENSA no puede investigar un incidente en OT porque no hay recolección de evidencia
Alcance	Red corporativa de TI, zona intermedia, red OT, enlaces con subestaciones y la cabecera del sistema de medición inteligente
Declaraciones de política	1. Todo evento de seguridad de los sistemas del alcance se envía a la plataforma central de alertas. 2. La red OT se monitorea con detección pasiva, sin inyectar tráfico ni interferir con la operación en tiempo real. 3. Los registros de flujo de la red se conservan al menos noventa días en línea y un año en archivo. 4. Toda alerta de severidad alta se atiende dentro de la hora siguiente a su generación, las veinticuatro horas del día. 5. Los umbrales de alerta se revisan mensualmente para mantener la proporción de falsos positivos por debajo del 20 %. 6. Ninguna regla de detección se desactiva sin aprobación de la Jefatura de Seguridad y registro del motivo
Roles y responsabilidades	Aprueba: Gerencia General. Rinde cuentas: Jefatura de Seguridad de la Información. Ejecuta: analista de seguridad de TO y analista de seguridad de TI. Consulta: Gerencia de Operaciones de Red para toda acción que pueda afectar la operación. Verifica: auditoría interna
Cumplimiento y excepciones	La desactivación no autorizada de una regla de detección o la manipulación de bitácoras se tratan como falta grave. Las excepciones por mantenimiento programado se registran con ventana declarada y se cierran al terminar
Revisión	Política anual; reglas de detección y umbrales, mensual. Dueño: Jefatura de Seguridad de la Información

F.3 SOP — procedimiento operativo (el cómo)

Sección	Contenido
Objetivo y disparador	Operar el monitoreo de seguridad y dar tratamiento a las alertas. Se ejecuta de forma continua, con revisión formal diaria de la cola de alertas y revisión mensual de umbrales
Responsable y frecuencia	Analista de seguridad de TO en horario hábil y turno de guardia de TI/TO fuera de él; frecuencia continua, con cierre diario y mensual

Sección	Contenido
Pasos numerados	1. Verificar al inicio de cada jornada que las fuentes de eventos declaradas están reportando; toda fuente en silencio por más de dos horas se investiga como incidente potencial. 2. Revisar la cola de alertas por severidad y antigüedad. 3. Clasificar cada alerta como falso positivo, evento sin consecuencia o incidente, con el criterio documentado. 4. Para las alertas de la red OT, contrastar con la bitácora de maniobras del centro de control antes de escalar, para descartar actividad legítima de operación. 5. Escalar los incidentes conforme al procedimiento de respuesta y abrir el registro del caso. 6. Documentar el cierre de cada alerta con su clasificación y su tiempo de atención. 7. Revisar mensualmente los umbrales y las reglas con más falsos positivos y ajustarlos con aprobación registrada. 8. Emitir el reporte mensual de monitoreo con volumen de alertas, tiempo medio de atención y proporción de falsos positivos
Evidencia generada	Cola de alertas con clasificación y tiempos; reporte mensual de monitoreo; registro de ajustes de umbrales; inventario de fuentes de eventos con su estado. Alimenta los indicadores IND-03 e IND-04 de E.09
Escalamiento	Toda alerta de severidad alta sobre activos de la red OT se comunica de inmediato al jefe de turno del centro de control y a la Jefatura de Seguridad. Si el indicio sugiere manipulación de comandos, se activa el procedimiento de respuesta a incidentes y se evalúa el paso a operación manual con la Gerencia de Operaciones de Red, que es quien decide esa activación según la RACI

F.4 Controles por tipo

Tipo	Qué documenta el equipo (2–4 por control)
Técnicos	Sonda de detección pasiva conectada a un puerto espejo en la zona intermedia y en el segmento de control, con reglas específicas para los protocolos industriales del fabricante del SCADA · plataforma central de alertas que recibe eventos de cortafuegos, anfitrión de salto, directorio corporativo, servidores del SCADA y del sistema comercial · recolección de registros de flujo de red con retención de noventa días en línea · filtrado de tráfico entre segmentos en el punto de la zona intermedia, compartido con el control 12
Administrativos	Procedimiento de clasificación y escalamiento de alertas, con criterios escritos · revisión mensual de umbrales con aprobación registrada · inventario de fuentes de eventos y verificación diaria de su reporte · acuerdo con la Gerencia de Operaciones de Red sobre las acciones que exigen su consulta previa
Físicos	Acceso restringido al gabinete donde se conecta la sonda pasiva y al equipamiento de la plataforma de alertas, dentro del centro de datos corporativo

Control 6 — Gestión del control de acceso

F.1 Identificación del control

Campo	Contenido
Control CIS v8.1	Control 6 — Gestión del control de acceso
Salvaguardas del IG asignado en este control	Ocho salvaguardas: 6.1 proceso de otorgamiento de acceso (IG1), 6.2 proceso de revocación (IG1), 6.3 MFA en aplicaciones expuestas (IG1), 6.4 MFA en acceso remoto a la red (IG1), 6.5 MFA en acceso administrativo (IG1), 6.6 inventario de sistemas de autenticación y autorización (IG2), 6.7 control de acceso centralizado (IG2), 6.8 control de acceso basado en roles (IG3). Se diseñan ahora las cinco de IG1 y la 6.6; pasan al roadmap 6.7 y 6.8, que exigen el inventario de la 6.6 como paso previo

Campo	Contenido
Riesgos que mitiga	R-02 (Crítico), R-07 (Crítico) y R-09 (Alto)
Correspondencia ISO	ISO/IEC 27002:2022, controles 5.15 control de acceso, 5.17 información de autenticación, 5.18 derechos de acceso y 8.5 autenticación segura
Función CSF 2.0	Proteger (PR.AA — gestión de identidades, autenticación y control de acceso)

F.2 Política (el qué y el porqué)

Sección	Contenido
Propósito	Impedir que una credencial comprometida se convierta en acceso administrativo a los sistemas que sostienen los dos procesos críticos y los procesos comerciales y de medición. Los dos riesgos Críticos que este control trata tienen la misma raíz: cuentas privilegiadas y acceso remoto de proveedores sin autenticación multifactor ni trazabilidad
Alcance	Todas las cuentas de ENSA: personal propio, proveedores y cuentas de servicio, en la red de TI, en la red OT y en las aplicaciones expuestas a internet
Declaraciones de política	1. Toda cuenta es nominal; las cuentas compartidas quedan prohibidas, incluidas las de soporte de proveedores. 2. El acceso administrativo, el acceso remoto a la red y las aplicaciones expuestas exigen autenticación multifactor sin excepción. 3. El acceso de un proveedor se habilita por sesión, con solicitud, aprobación del dueño del sistema y ventana de tiempo declarada; fuera de esa ventana el acceso permanece deshabilitado. 4. Las sesiones administrativas sobre el entorno de control se graban y se conservan por un año. 5. El alta y la baja de accesos siguen el proceso documentado, con revocación dentro de las cuatro horas siguientes a la separación de un colaborador. 6. Los derechos de acceso se revisan semestralmente por el dueño de cada sistema. 7. Las cuentas locales de emergencia de las estaciones HMI se custodian en sobre sellado, con registro de apertura y cambio de credencial tras cada uso
Roles y responsabilidades	Aprueba: Gerencia General. Rinde cuentas: Jefatura de Seguridad de la Información. Ejecuta: unidad TI/TO. Consulta: dueños de proceso para la revisión de derechos. Informa: Recursos Humanos, que notifica altas y bajas de personal. Coincide con la RACI de E.06
Cumplimiento y excepciones	El uso de cuentas compartidas o la elusión del segundo factor se tratan como falta grave y motivan la suspensión inmediata del acceso. Las excepciones se aprueban por escrito con medida compensatoria y vencimiento máximo de treinta días
Revisión	Política anual; revisión de derechos de acceso semestral; inventario de sistemas de autenticación, anual. Dueño: Jefatura de Seguridad de la Información

F.3 SOP — procedimiento operativo (el cómo)

Sección	Contenido
Objetivo y disparador	Otorgar, habilitar por sesión, revisar y revocar accesos. Los disparadores son: solicitud de alta, notificación de baja por Recursos Humanos, solicitud de sesión de proveedor, revisión semestral programada y todo incidente que involucre una credencial
Responsable y frecuencia	Administrador de identidades de TI/TO; continuo por solicitud, con revisión semestral de derechos y revisión mensual del inventario de cuentas privilegiadas

Sección	Contenido
Pasos numerados	1. Recibir la solicitud con el rol requerido y la aprobación del dueño del sistema. 2. Verificar que el rol solicitado corresponde al puesto y aplicar el privilegio mínimo. 3. Crear la cuenta nominal, registrar su dueño y habilitar el segundo factor antes del primer uso. 4. Para proveedores: verificar la solicitud de sesión, confirmar la ventana autorizada, habilitar la cuenta en el concentrador de acceso, activar la grabación y deshabilitarla al cierre de la ventana. 5. Ante una baja notificada por Recursos Humanos, revocar todos los accesos dentro de las cuatro horas y registrar la hora de ejecución. 6. Revisar mensualmente el listado de cuentas privilegiadas y confirmar con su dueño que siguen siendo necesarias. 7. Conducir la revisión semestral de derechos con cada dueño de sistema y retirar lo que no se confirme. 8. Emitir el reporte mensual de accesos con altas, bajas, sesiones de proveedor y hallazgos
Evidencia generada	Solicitudes y aprobaciones de acceso; registro de sesiones de proveedor con ventana y grabación; bitácora de revocaciones con marca de tiempo; actas de la revisión semestral de derechos; inventario de cuentas privilegiadas. Alimenta los indicadores IND-05 e IND-06 de E.09
Escalamiento	Toda cuenta privilegiada sin dueño identificado se deshabilita dentro de las 24 horas. Un acceso de proveedor fuera de la ventana autorizada se corta de inmediato, se informa a la Jefatura de Seguridad y a la Gerencia General y se trata como incidente de seguridad con notificación contractual al proveedor

F.4 Controles por tipo

Tipo	Qué documenta el equipo (2–4 por control)
Técnicos	Autenticación multifactor en el directorio corporativo, en el portal de clientes, en la red privada virtual y en toda sesión administrativa · concentrador de acceso para proveedores con habilitación por sesión, aprobación en línea y grabación · gestión de acceso privilegiado con custodia y rotación de credenciales de administración del SCADA y del sistema comercial · endurecimiento de los controladores de dominio con el CIS Microsoft Windows Server 2019 Benchmark, la versión que declara la ficha
Administrativos	Proceso documentado de alta, cambio y baja de accesos con acuerdo de servicio de cuatro horas para la revocación · revisión semestral de derechos con acta por dueño de sistema · cláusula contractual que obliga al proveedor a usar cuentas nominales y aceptar la grabación de sesión, coordinada con el control 15 · custodia en sobre sellado de las cuentas de emergencia de las estaciones HMI
Físicos	Resguardo del sobre sellado de credenciales de emergencia en la caja fuerte del centro de control, con registro de apertura

Control 7 — Gestión continua de vulnerabilidades

F.1 Identificación del control

Campo	Contenido
Control CIS v8.1	Control 7 — Gestión continua de vulnerabilidades

Campo	Contenido
Salvaguardas del IG asignado en este control	Siete salvaguardas: 7.1 proceso de gestión de vulnerabilidades (IG1), 7.2 proceso de remediación (IG1), 7.3 parcheo automatizado de sistemas operativos (IG1), 7.4 parcheo automatizado de aplicaciones (IG1), 7.5 escaneo automatizado de activos internos (IG2), 7.6 escaneo de activos expuestos externamente (IG2), 7.7 remediación de vulnerabilidades detectadas (IG2). Se diseñan las siete: las cuatro de IG1 y la 7.6 con alcance inmediato, y la 7.5 y la 7.7 con alcance diferenciado entre la red de TI, donde operan desde el inicio, y la red OT, donde el escaneo activo queda restringido a las ventanas de mantenimiento acordadas con el fabricante. Ninguna pasa al roadmap
Riesgos que mitiga	R-12 (Alto), con efecto sobre R-01 y R-04 al reducir la superficie explotable
Correspondencia ISO	ISO/IEC 27002:2022, controles 8.8 gestión de vulnerabilidades técnicas y 8.32 gestión de cambios
Función CSF 2.0	Identificar (ID.RA — evaluación de riesgos) con ejecución en Proteger (PR.PS — seguridad de plataformas)

F.2 Política (el qué y el porqué)

Sección	Contenido
Propósito	Reducir la exposición a vulnerabilidades publicadas en los servidores, las estaciones HMI y las aplicaciones que sostienen los procesos críticos. Hoy ENSA parchea el entorno de control solo cuando el fabricante lo autoriza, sin calendario ni criterio de prioridad, y esa condición sostiene el riesgo R-12
Alcance	Servidores y estaciones de la red corporativa, servidores de adquisición y aplicación del SCADA, estaciones HMI y de ingeniería, sistema OMS, sistema comercial, portal de clientes y equipos de la cabecera de medición inteligente
Declaraciones de política	1. Todo activo del inventario tiene un responsable de su parcheo declarado. 2. Las vulnerabilidades se priorizan por riesgo para el proceso que sostiene el activo, y no solo por su puntaje técnico. 3. Los plazos de remediación son: crítica en 15 días, alta en 30, media en 90, en la red de TI. 4. En la red OT los mismos plazos aplican a la decisión de tratamiento, y la ejecución se realiza en la ventana de mantenimiento más próxima; cuando el fabricante no libera corrección, se documenta y se aplica una medida compensatoria. 5. El escaneo de la red OT es pasivo o se ejecuta en ventana acordada, nunca sobre el sistema en operación. 6. Ningún activo opera con software fuera de soporte del fabricante sin excepción aprobada y medida compensatoria
Roles y responsabilidades	Aprueba: Gerencia General. Rinde cuentas: Jefatura de Seguridad de la Información. Ejecuta: TI/TO, con la Gerencia de Operaciones de Red para las ventanas del entorno de control. Verifica: auditoría interna
Cumplimiento y excepciones	El incumplimiento de un plazo de remediación se reporta en la revisión trimestral por la dirección. Las excepciones exigen medida compensatoria documentada, aprobación de la Jefatura de Seguridad y vencimiento máximo de ciento ochenta días
Revisión	Política anual; calendario de ventanas de mantenimiento, semestral; criterios de priorización, anual. Dueño: Jefatura de Seguridad de la Información

F.3 SOP — procedimiento operativo (el cómo)

Sección	Contenido
Objetivo y disparador	Detectar, priorizar y remediar vulnerabilidades. Disparadores: escaneo programado semanal en TI, escaneo pasivo continuo en OT, aviso de vulnerabilidad crítica publicada por el fabricante o por el centro de respuesta sectorial, y todo cambio mayor en una plataforma
Responsable y frecuencia	Analista de seguridad de TI para el ciclo semanal; analista de seguridad de TO para el entorno de control; ventanas de mantenimiento trimestrales acordadas con Operaciones de Red
Pasos numerados	1. Ejecutar el escaneo autenticado semanal sobre la red corporativa y el escaneo externo mensual sobre el portal de clientes. 2. Consolidar los hallazgos con el inventario de activos de E.04 para identificar el proceso que sostiene cada activo. 3. Priorizar con la matriz de riesgo: severidad técnica combinada con la criticidad del proceso. 4. Asignar cada hallazgo a su responsable con el plazo que corresponde. 5. Para la red OT, consultar el boletín del fabricante del SCADA, determinar si existe corrección y, cuando no exista, definir la medida compensatoria con la Jefatura de Seguridad. 6. Programar la aplicación de correcciones del entorno de control en la ventana de mantenimiento, con respaldo previo y plan de reversión. 7. Verificar la remediación con un nuevo escaneo o con la comprobación de versión. 8. Emitir el reporte mensual de vulnerabilidades con hallazgos abiertos, cerrados y vencidos
Evidencia generada	Reportes de escaneo semanal y externo; registro de hallazgos con responsable, plazo y estado; actas de ventana de mantenimiento con respaldo y plan de reversión; reporte mensual de vulnerabilidades. Alimenta los indicadores IND-07 e IND-08 de E.09
Escalamiento	Una vulnerabilidad crítica explotable en un activo de un proceso crítico se informa a la Jefatura de Seguridad y a la Gerencia de Operaciones de Red dentro de las 24 horas, y se convoca una ventana de mantenimiento extraordinaria si la medida compensatoria no reduce la exposición. Todo hallazgo vencido escala a la Gerencia General en la revisión trimestral

F.4 Controles por tipo

Tipo	Qué documenta el equipo (2–4 por control)
Técnicos	Escáner de vulnerabilidades con credenciales para la red corporativa, con ejecución semanal · escaneo externo mensual del portal de clientes y de los servicios publicados · descubrimiento pasivo en la red OT, sin sondeo activo · gestión centralizada de parches del sistema operativo y de las aplicaciones de la red corporativa, con los CIS Benchmarks de las versiones que declara la ficha como línea de configuración (Microsoft Windows 11 Enterprise, Microsoft Windows 10 Enterprise para las estaciones HMI con LTSC 2019, Red Hat Enterprise Linux 8, SUSE Linux Enterprise 15 y Oracle Database 19c) · hallazgo de fin de soporte: las estaciones del parque heredado con Windows 10 perdieron el soporte de Microsoft el 14 de octubre de 2025; su sustitución por Windows 11 pasa a E.10 como iniciativa de corto plazo; las estaciones HMI con Windows 10 Enterprise LTSC 2019 conservan soporte hasta el 9 de enero de 2029
Administrativos	Calendario de ventanas de mantenimiento acordado con Operaciones de Red y con el fabricante del SCADA · criterio escrito de priorización por criticidad del proceso · registro de excepciones con medida compensatoria y vencimiento · cláusula contractual que obliga al fabricante a informar vulnerabilidades y a liberar correcciones, coordinada con el control 15
Físicos	Resguardo de los medios de instalación y de las imágenes de recuperación de las estaciones HMI en el gabinete del centro de control

Control 11 — Recuperación de datos

F.1 Identificación del control

Campo	Contenido
Control CIS v8.1	Control 11 — Recuperación de datos
Salvaguardas del IG asignado en este control	Cinco salvaguardas: 11.1 proceso de recuperación de datos (IG1), 11.2 respaldos automatizados (IG1), 11.3 protección de los datos de recuperación (IG1), 11.4 instancia aislada de datos de recuperación (IG1), 11.5 prueba de recuperación (IG2). Se diseñan las cinco, sin excepciones: la brecha B-01 del BIA impide dejar cualquiera de ellas para el roadmap
Riesgos que mitiga	R-06 (Alto) de forma directa, y reduce el impacto de R-01 (Crítico) al acortar el tiempo de recuperación tras un cifrado del entorno
Correspondencia ISO	ISO/IEC 27002:2022, controles 8.13 respaldo de información y 5.29 seguridad de la información durante la disrupción; ISO 22301:2019 para la continuidad
Función CSF 2.0	Recuperar (RC.RP — ejecución del plan de recuperación)

F.2 Política (el qué y el porqué)

Sección	Contenido
Propósito	Garantizar que ENSA recupere el entorno de control dentro del objetivo de dos horas y con una pérdida de datos no mayor a quince minutos. El análisis de impacto verificó que el respaldo vigente, semanal y en cinta, no sostiene ninguno de los dos objetivos declarados
Alcance	Base de datos de tiempo real y configuración del sistema SCADA, sistema OMS, sistema comercial SAP IS-U, base de datos de clientes, cabecera de medición inteligente, configuración de los equipos de red y del punto de filtrado
Declaraciones de política	1. Todo sistema del alcance tiene respaldo automatizado con frecuencia derivada de su objetivo de punto de recuperación: quince minutos para el entorno SCADA, una hora para el OMS, cuatro horas para el sistema comercial. 2. Existe al menos una copia aislada de la red, inmutable durante su período de retención. 3. Los respaldos se cifran en tránsito y en reposo, y su acceso se restringe a cuentas nominales con autenticación multifactor. 4. La restauración se prueba trimestralmente para el entorno SCADA y semestralmente para los demás sistemas, con registro del tiempo alcanzado. 5. Ninguna prueba se declara satisfactoria sin verificación funcional del sistema restaurado por su dueño de proceso. 6. El resultado de cada prueba se compara con el RTO y el RPO declarados en el BIA y toda desviación se trata como hallazgo
Roles y responsabilidades	Aprueba: Gerencia General. Rinde cuentas: Jefatura de Seguridad de la Información. Ejecuta: TI/TO. Valida funcionalmente: dueño de cada proceso. Verifica: auditoría interna
Cumplimiento y excepciones	La ausencia de prueba de restauración en el período declarado se reporta como no conformidad. No se admiten excepciones sobre la copia aislada del entorno de control
Revisión	Política anual; calendario de pruebas, semestral; verificación del cumplimiento de objetivos, en cada prueba. Dueño: Jefatura de Seguridad de la Información

F.3 SOP — procedimiento operativo (el cómo)

Sección	Contenido
Objetivo y disparador	Ejecutar, proteger y probar los respaldos. Disparadores: calendario diario de respaldo, calendario trimestral y semestral de pruebas, todo cambio de configuración relevante en el SCADA y toda declaración de incidente con posible pérdida de datos
Responsable y frecuencia	Administrador de plataformas de TI/TO; respaldo diario automatizado con copia incremental cada quince minutos del entorno SCADA; prueba trimestral del SCADA y semestral del resto
Pasos numerados	1. Verificar cada mañana el resultado del ciclo de respaldo y atender los trabajos fallidos antes del mediodía. 2. Confirmar la replicación a la instancia aislada y la retención inmutable vigente. 3. Programar la prueba trimestral con el dueño del proceso y reservar el entorno de laboratorio. 4. Restaurar la base de datos de tiempo real y la configuración del SCADA en el entorno de laboratorio, midiendo el tiempo desde el inicio hasta el sistema operable. 5. Solicitar al dueño del proceso la verificación funcional: lectura de señales, comando simulado y reconciliación de estados. 6. Registrar el tiempo alcanzado y compararlo con el RTO de dos horas y el RPO de quince minutos. 7. Documentar los hallazgos y abrir acciones correctivas cuando el objetivo no se alcance. 8. Emitir el reporte trimestral de recuperación con los resultados y las acciones abiertas
Evidencia generada	Bitácora diaria de trabajos de respaldo con resultado; reporte de replicación e inmutabilidad; acta de prueba de restauración con tiempo medido y verificación funcional firmada por el dueño del proceso; reporte trimestral de recuperación. Alimenta los indicadores IND-09 e IND-10 de E.09
Escalamiento	Dos ciclos consecutivos de respaldo fallidos sobre un sistema de proceso crítico se tratan como incidente y se informan a la Jefatura de Seguridad el mismo día. Una prueba de restauración que no alcance el RTO se eleva a la Gerencia General con propuesta de inversión en la revisión trimestral

F.4 Controles por tipo

Tipo	Qué documenta el equipo (2–4 por control)
Técnicos	Respaldo automatizado con copia incremental cada quince minutos del entorno SCADA y diaria del resto · repositorio inmutable con retención de treinta días en la copia aislada, sin credenciales compartidas con el dominio corporativo · cifrado de respaldos en tránsito y en reposo · entorno de laboratorio con capacidad para restaurar la plataforma de control sin tocar producción
Administrativos	Calendario anual de pruebas de restauración con dueños de proceso convocados · acta de prueba con tiempo medido y verificación funcional firmada · procedimiento de reversión documentado para el entorno de control · revisión semestral de la vigencia de las retenciones frente a los requisitos legales de conservación
Físicos	Custodia de los medios de la copia aislada en una ubicación distinta del centro de datos corporativo, con control de acceso y registro de retiro

Control 15 — Gestión de proveedores de servicios

F.1 Identificación del control

Campo	Contenido
Control CIS v8.1	Control 15 — Gestión de proveedores de servicios

Campo	Contenido
Salvaguardas del IG asignado en este control	Siete salvaguardas: 15.1 inventario de proveedores (IG1), 15.2 política de gestión de proveedores (IG2), 15.3 clasificación de proveedores (IG2), 15.4 requisitos de seguridad en contratos (IG2), 15.5 evaluación de proveedores (IG3), 15.6 monitoreo de proveedores (IG3), 15.7 desvinculación segura (IG3). Se diseñan ahora 15.1, 15.2, 15.3, 15.4 y 15.7; pasan al roadmap 15.5 y 15.6, que exigen el programa de evaluación periódica y el mecanismo de monitoreo continuo que el mediano plazo construye
Riesgos que mitiga	R-09 (Alto), R-02 (Crítico) en su componente contractual y R-14 (Alto) por el contrato de respuesta del fabricante
Correspondencia ISO	ISO/IEC 27002:2022, controles 5.19 a 5.22 sobre seguridad en las relaciones con proveedores y gestión de servicios prestados por terceros
Función CSF 2.0	Gobernar (GV.SC — gestión del riesgo de la cadena de suministro)

F.2 Política (el qué y el porqué)

Sección	Contenido
Propósito	Hacer exigible la seguridad a los terceros que sostienen la operación de ENSA. El fabricante del sistema SCADA, el proveedor de la plataforma de medición y la pasarela de pagos tienen acceso o influencia directa sobre procesos críticos, y hoy los contratos no contienen obligaciones de seguridad verificables
Alcance	Todo proveedor con acceso a sistemas o datos de ENSA, con conexión a la red corporativa o a la red OT, o con responsabilidad sobre un componente de un proceso crítico o importante
Declaraciones de política	1. Existe un inventario único de proveedores con su servicio, su criticidad y su contacto de seguridad. 2. Los proveedores se clasifican en tres niveles según su acceso y el proceso que sostienen; el nivel determina las obligaciones contractuales. 3. Todo contrato con proveedor de nivel crítico incluye: cuentas nominales, autenticación multifactor, aceptación de grabación de sesión, notificación de incidentes dentro de las 24 horas, derecho de auditoría, requisitos de verificación de integridad de actualizaciones y devolución o destrucción de datos al término. 4. Ningún acceso de proveedor se habilita sin contrato vigente que contenga esas cláusulas. 5. La desvinculación de un proveedor sigue un procedimiento formal con revocación de accesos, devolución de datos y cierre de cuentas. 6. Los proveedores de nivel crítico entregan evidencia anual de sus propios controles
Roles y responsabilidades	Aprueba: Gerencia General. Rinde cuentas: Jefatura de Seguridad de la Información. Ejecuta y negocia: función de cumplimiento adscrita a Finanzas, con la unidad requirente. Consulta: TI/TO. Verifica: auditoría interna. Coincide con la fila de gestión de la seguridad en contratos de la RACI de E.06
Cumplimiento y excepciones	Ningún proveedor de nivel crítico opera sin las cláusulas exigidas; la excepción la aprueba la Gerencia General por escrito, con plazo máximo de noventa días y medida compensatoria en el acceso
Revisión	Política anual; inventario y clasificación, semestral; cláusulas modelo, anual o ante cambio normativo. Dueño: Jefatura de Seguridad de la Información

F.3 SOP — procedimiento operativo (el cómo)

Sección	Contenido
Objetivo y disparador	Mantener el inventario, clasificar, contratar con requisitos de seguridad y desvincular proveedores. Disparadores: solicitud de contratación nueva, renovación de contrato, revisión semestral del inventario, incidente que involucre a un proveedor y término de la relación
Responsable y frecuencia	Analista de cumplimiento con la Jefatura de Seguridad; continuo por solicitud, con revisión semestral del inventario
Pasos numerados	1. Registrar al proveedor en el inventario con servicio, sistemas a los que accede y proceso que sostiene. 2. Clasificarlo en nivel crítico, relevante o estándar con el criterio de acceso y criticidad del proceso. 3. Incorporar al contrato el anexo de seguridad correspondiente a su nivel. 4. Verificar antes de habilitar el acceso que el contrato está firmado y que el proveedor designó contacto de seguridad. 5. Coordinar con el control 6 la habilitación por sesión del acceso remoto. 6. Solicitar anualmente la evidencia de controles a los proveedores de nivel crítico y registrar su resultado. 7. Al término de la relación, ejecutar la desvinculación: revocar accesos, recuperar activos, confirmar devolución o destrucción de datos y cerrar el registro. 8. Emitir el reporte semestral del estado del inventario y de las cláusulas pendientes
Evidencia generada	Inventario de proveedores con clasificación y fecha de revisión; contratos con anexo de seguridad firmado; evidencia anual de controles de los proveedores críticos; actas de desvinculación; reporte semestral. Alimenta los indicadores IND-11 e IND-12 de E.09
Escalamiento	Un proveedor de nivel crítico que opere sin anexo de seguridad se reporta a la Gerencia General en la siguiente revisión por la dirección y su acceso se suspende si la regularización excede los noventa días. Un incidente en un proveedor que afecte a ENSA activa el procedimiento de respuesta a incidentes y la cláusula de notificación contractual

F.4 Controles por tipo

Tipo	Qué documenta el equipo (2–4 por control)
Técnicos	Verificación de integridad de las actualizaciones que el fabricante del SCADA entrega, con comprobación de firma antes de su aplicación · acceso de proveedores canalizado por el concentrador con grabación, compartido con el control 6 · segmentación del enlace de la pasarela de pagos respecto de la red interna
Administrativos	Inventario y clasificación de proveedores con revisión semestral · anexo de seguridad por nivel, con las cláusulas exigibles del contrato · contrato de respuesta del fabricante del SCADA en cuatro horas, que atiende el punto único de falla SPOF-01 · procedimiento de desvinculación con acta · solicitud anual de evidencia de controles
Físicos	Registro de ingreso del personal de proveedores a subestaciones, centro de control y centro de datos, con acompañamiento obligatorio

Cierre del entregable

Los seis controles desarrollados documentan 46 de las 153 salvaguardas del baseline IG3 en sus tablas F.1 —ocho del control 12, once del 13, ocho del 6, siete del 7, cinco del 11 y siete del 15—, de las cuales quince pertenecen al IG1. Las 107 salvaguardas restantes se mapean en el checklist de E.08, donde 41 son de IG1: 15 + 41 = 56, la base común de higiene cibernética esencial, y 46 + 107 = 153, el baseline IG3 asignado a ENSA. Cada control nombra los riesgos de E.05 que mitiga, cada política declara roles coherentes con la RACI de E.06, y cada procedimiento genera la evidencia que alimenta los indicadores de E.09.